

LVChat

Full Monty Audit Report

1 CRITICAL · 7 HIGH · 4 MEDIUM · 0 LOW

Generated: August 18, 2026 at 08:19 PM
Scope: FULL_MONTY
Total findings: 12 · Security: 2 · Performance: 3 · UI/UX: 7

Executive Summary

Metric	Value
Total Findings	12
Critical Severity	1
High Severity	7
Medium Severity	4
Low Severity	0
---	---
Security findings	2
Performance findings	3
UI/UX findings	7
---	---
GPT-OSS-20b findings	0
MiniMax/grep findings	12

Methodology

Security scan (Step 2.5): Two-model parallel approach. Model A — GPT-OSS-20b at 192.168.8.147:1234 (Botbox2): static per-file security review using a 6-thread worker pattern. Model B — MiniMax + local grep sweep: regex/heuristic pass over all source files. Vulnerability classes scanned: SQLi, XSS, CSRF, IDOR,

AuthBypass, HardcodedSecret, SessionHardening, FileUpload/PathTraversal, TimingAttack, Cron/TOCTOU, InfoDisclosure, InsecureDeserialization, OpenRedirect, MissingRateLimit, CORS/OriginCheck, HeaderInjection.

Performance scan (Step 2.6): Same two-model pattern. Classes scanned: N+1, MissingIndex, UnboundedResultSet, SyncExternalCall, MissingCache, AssetBloat, RenderBlocking, ExcessiveDOM, MemoryHotPath, ResourceLeaks, CronInefficiency, ColdStart, FrontendRuntime, NetworkPayload, ConnectionPool, Concurrency.

UI/UX scan (Step 2.7): Same two-model pattern plus Playwright screenshot review where available. Classes scanned: a11y, FormUX, LoadingStates, ErrorUX, InformationArchitecture, VisualConsistency, ResponsiveDesign, i18n, StateFeedback, Discoverability, NativeDialog, DataBinding, DeadUI, ColorContrast, Microcopy, Motion, PrintExport.

Severity scale: Critical (direct exploit / unusability) → High (realistic exploit / visible breakage) → Medium (preconditions / tolerable lag) → Low (defense-in-depth / polish).

Scope rule (CRITICAL): *install/*, *e2e/*, and *tests/* directories are excluded from live-code audit scope. They are development-only and must never reach production. These folders should be manually deleted before any upload.

Security Findings

2 finding(s): 0 Critical · 0 High · 2 Medium · 0 Low

H-01	MEDIUM	Missing Security Header	MiniMax (grep sweep)
File : Line	src/bootstrap.php : 197		
Vulnerable Code	// HSTS only — no CSP, no X-Content-Type-Options, no Referrer-Policy		
Description	Application lacked Content-Security-Policy, X-Content-Type-Options, and Referrer-Policy headers. XSS exploitation was unco		
Remediation	Added CSP (default-src 'self' + controlled exceptions), X-Content-Type-Options: nosniff, Referrer-Policy: strict-origin-when-cro		

H-02	MEDIUM	LIKE Wildcard Injection	MiniMax (grep sweep)
File : Line	src/controllers/AdminController.php : 118		
Vulnerable Code	\$params = ["%\$term%", "%\$term%"];		
Description	User search term used in LIKE clause without escaping % and _ metacharacters. Attackers could inject wildcards to match bro		
Remediation	Wrapped \$term with addcslashes(\$term, '%_\\') before LIKE parameterization.		

Performance Findings

3 finding(s): 0 Critical · 2 High · 1 Medium · 0 Low

P-01	HIGH	Missing Index	MiniMax (grep sweep)
File : Line	schema.sql : 4		
Vulnerable Code	CREATE TABLE users (...last_ip TEXT, last_seen TEXT...)		
Description	users.last_ip and users.last_seen had no indexes. IP ban lookups and online-user queries performed full table scans.		
Remediation	Added idx_users_last_seen and idx_users_last_ip indexes in schema v41 migration.		
P-02	HIGH	Missing Index	MiniMax (grep sweep)
File : Line	schema.sql : 250		
Vulnerable Code	CREATE TABLE chat_logs (...)		
Description	chat_logs.channel_name had no index. Admin log export and event log queries scanned the entire append-only table.		
Remediation	Added idx_chat_logs_channel (channel_name, created_at) composite index in schema v41 migration.		
P-03	MEDIUM	Missing Caching	MiniMax (grep sweep)
File : Line	src/services/UrlBanService.php : 73		
Vulnerable Code	Database::all('SELECT * FROM banned_urls')		
Description	Full banned_urls table loaded on every embed fetch and channel URL validation with no caching.		
Remediation	Added per-request static cache (\$cachedBans) invalidated on add()/remove() admin operations.		

UI/UX Findings

7 finding(s): 1 Critical · 5 High · 1 Medium · 0 Low

U-01	CRITICAL	Accessibility	MiniMax (grep sweep)
File : Line	views/layout.php : 52		
Vulnerable Code			
Description	Site logo had empty alt="" on every page. Screen readers announced nothing for the primary site identifier.		
Remediation	Changed to alt="<?= h(config_get('site_name', 'LVChat')) ?>" across layout.php and all 6 auth views.		

U-02	HIGH	Accessibility	MiniMax (grep sweep)
File : Line	views/chat/app.php : 711		
Vulnerable Code	<textarea id="chat-input" name="content" ...>		
Description	Chat textarea had no aria-label or associated label element. Screen readers could not identify the primary input.		
Remediation	Added aria-label="Message input" to the textarea element.		

U-03	HIGH	Accessibility	MiniMax (grep sweep)
File : Line	views/chat/join.php : 31		
Vulnerable Code	<input class="input" type="password" name="key" placeholder="Channel key">		
Description	Channel key input had no <label> element, only placeholder text.		
Remediation	Added <label class="label" for="join-key">Channel key</label> above the input and id="join-key" to the input.		

U-04	HIGH	Accessibility	MiniMax (grep sweep)
File : Line	views/browse/index.php : 99		
Vulnerable Code	<input id="ch-search" ... placeholder="Search by name or topic...">		
Description	Channel browser search and filter controls had no aria-label attributes.		
Remediation	Added aria-label="Search channels" and aria-label="Filter channels" to the respective inputs.		

U-05	HIGH	Motion	MiniMax (grep sweep)
File : Line	src/assets/input.css : 379		
Vulnerable Code	@keyframes msg-in { ... }		
Description	Five @keyframes animations (msg-in, typing-bounce, modal-in, pulse-dot, browse-modal-in) ran without respecting prefers-reduced-motion.		
Remediation	Added @media (prefers-reduced-motion: reduce) block that disables all animations and transitions for affected elements.		

U-06	HIGH	Print	MiniMax (grep sweep)
File : Line	src/assets/input.css : 304		
Vulnerable Code	body.chat-app { position: fixed; inset: 0; overflow: hidden; }		
Description	No @media print styles anywhere. The chat app's fixed positioning caused blank pages when printing. Admin pages had no pr		
Remediation	Added @media print rules: hide chrome (sidebar, composer, actions), set body to static, ensure message list is visible, basic li		

U-07	MEDIUM	Form UX	MiniMax (grep sweep)
File : Line	views/chat/app.php : 723		
Vulnerable Code	Type / for commands · @nick to mention · ...		
Description	Hint bar was missing :emoji: shortcut documentation.		
Remediation	Added :emoji: and ~~strikethrough~~ to the hint bar text.		